

METASSÛR

OU COMMENT EMPÊCHER LES UTILISATEURS DE FAIRE N'IMPORTE QUOI
AVEC UN SITE WEB ?

Théo Besse

Sébastien Bonnaillie

Yann Villellas

Lucas Pettinato

Nathan-Gabriel Pundogar

Charles Duval

COMMENT RENFORCER LA SÉCURITÉ ET L'INTÉGRITÉ DE LA PLATEFORME EN LIGNE METASSUR ?

- I. Détail des utilisateurs et de leurs besoins
- II. Les problèmes juridiques
- III. Les problèmes de sécurité
- IV. Notre solutions : Métassûr



I. DÉTAIL DES UTILISATEURS ET DE LEURS BESOINS

Classe : client

RECEVUE

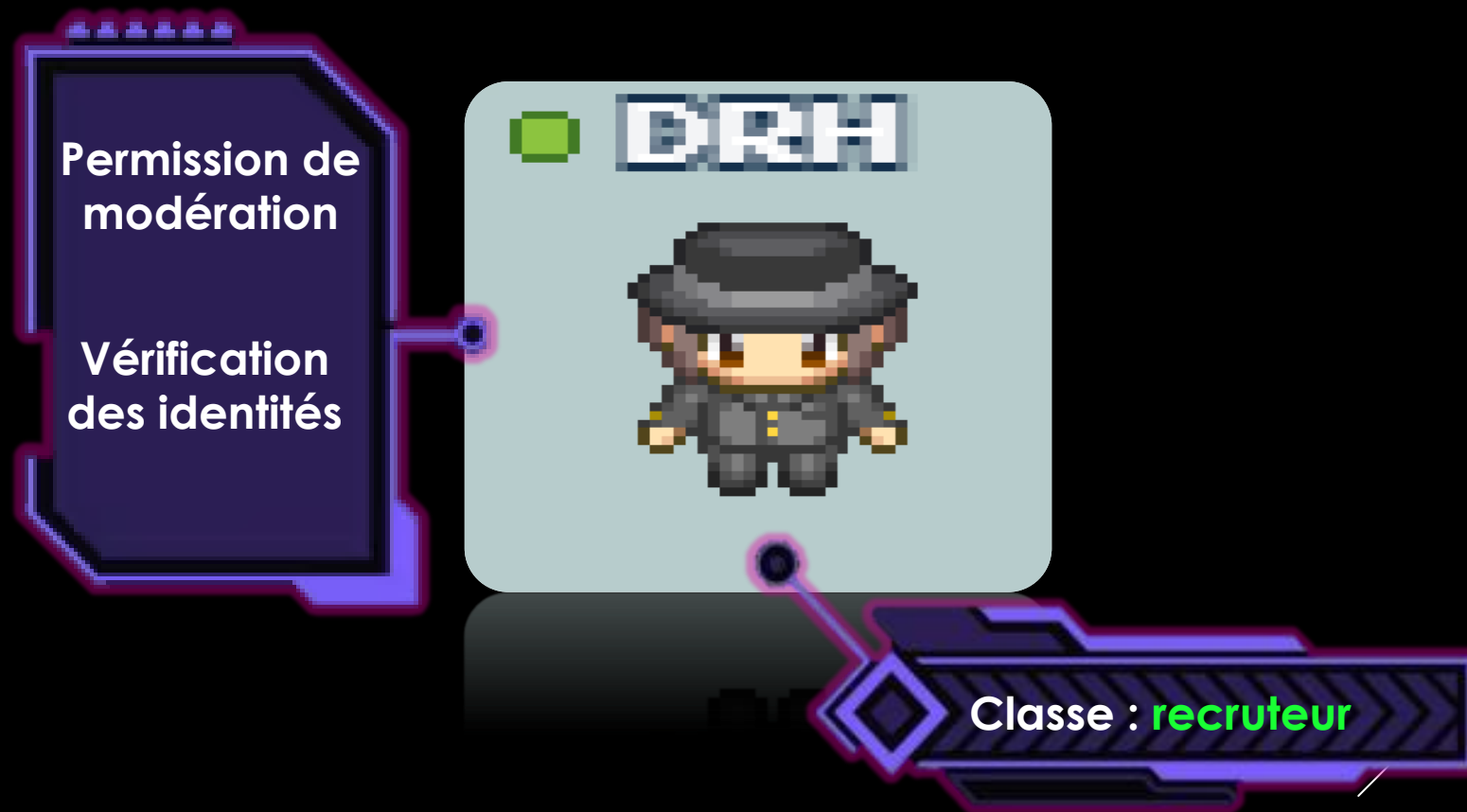


Confidentialité

Protection des données

Anonymat

I. DÉTAIL DES UTILISATEURS ET DE LEURS BESOINS



I. DÉTAIL DES UTILISATEURS ET DE LEURS BESOINS



II. LES PROBLÈMES JURIDIQUES

- ▶ Les pseudos
 - ▶ Usurpation d'identité
article 434-23 du Code pénal
 - ▶ Escroquerie
article L313-1 du Code pénal
 - ▶ Caractères illicites
 - ▶ Absence de filtres
 - ▶ Non unicité

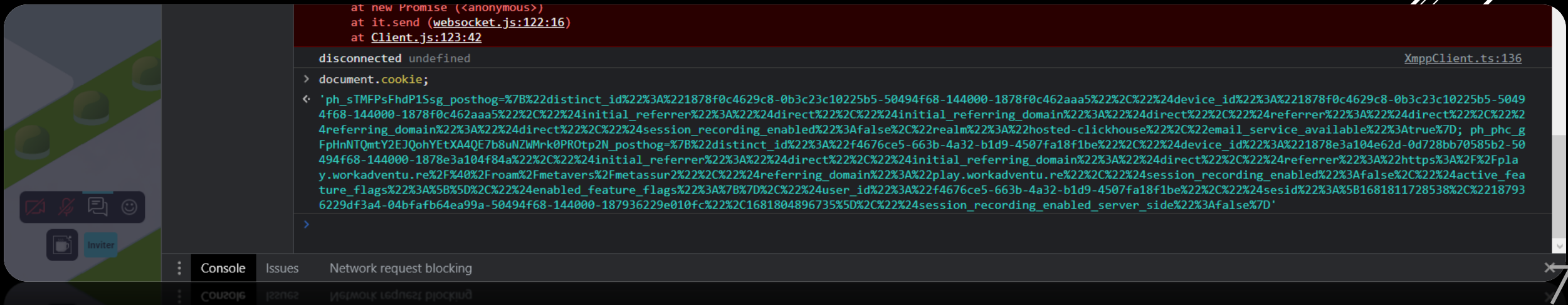


II. LES PROBLÈMES JURIDIQUES

- ▶ Confidentialité
 - ▶ Accès automatique à la caméra des autres
- ▶ Cookie
 - ▶ Impossibilité de les refuser
article 4 et 7 du RGPD
 - ▶ Pas de Hash unique pour prouver le consentement
lignes directrices de la CNIL : 17 décembre 2020



The image shows a dark-themed login interface for 'WorkAdventure'. At the top left is a logo of a coffee cup with steam. To its right is the text 'WorkAdventure' in a large, white, sans-serif font. Below the logo and name, the text 'Entrez votre nom' (Enter your name) is centered. Underneath is a white rectangular input field. Further down, a line of text states: 'En continuant, vous acceptez nos conditions d'utilisation, notre politique de confidentialité et notre politique relative aux cookies.' The words 'nos conditions d'utilisation', 'notre politique de confidentialité', and 'notre politique relative aux cookies' are in blue, indicating they are links. At the bottom right is a blue button with the white text 'Continuer'.



The image is a screenshot of a web browser's developer console. The top part shows a JavaScript error: 'Disconnected: undefined' with the source 'XmppClient.ts:136'. Below the error, the console shows the value of 'document.cookie', which is a very long string of cookies. The cookies include identifiers like 'ph_sTMFPsFhdP1Ssg_posthog', 'initial_referrer', 'direct', 'initial_referring_domain', 'session_recording_enabled', 'realm', 'hosted-clickhouse', 'email_service_available', 'ph_phc_gFpHnNTQmtY2EJQohYEtXA4QE7b8uNZWMrk0PROtp2N_posthog', 'device_id', 'initial_referring_domain', 'direct', 'referrer', 'https', 'active_feature_flags', 'enabled_feature_flags', 'user_id', 'sesid', and 'session_recording_enabled_server_side'. The bottom of the screenshot shows the browser's interface with tabs for 'Console', 'Issues', and 'Network request blocking'.

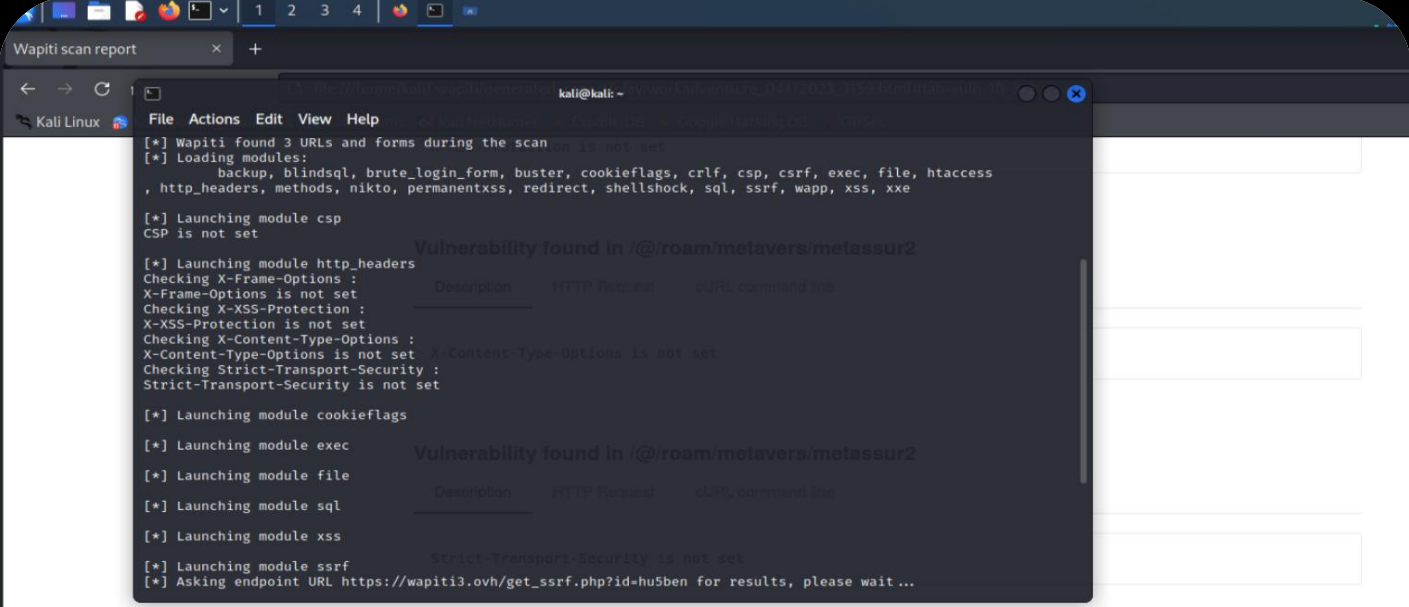
III. LES PROBLÈMES DE SÉCURITÉ

- ▶ Failles de sécurités découvertes
 - ▶ CSP is not set
 - ▶ X-XSS-Protection is not set
 - ▶ X-Content-Type-Options is not set
 - ▶ Strict-Transport-Security is not set

```
File Actions Edit View Help
[*] Wapiti found 3 URLs and forms during
[*] Loading modules:
    backup, blindsql, brute_login_fo
, http_headers, methods, nikto, permanent

[*] Launching module csp
CSP is not set

[*] Launching module http_headers
Checking X-Frame-Options :
X-Frame-Options is not set
Checking X-XSS-Protection :
X-XSS-Protection is not set
Checking X-Content-Type-Options :
X-Content-Type-Options is not set
Checking Strict-Transport-Security :
Strict-Transport-Security is not set
```



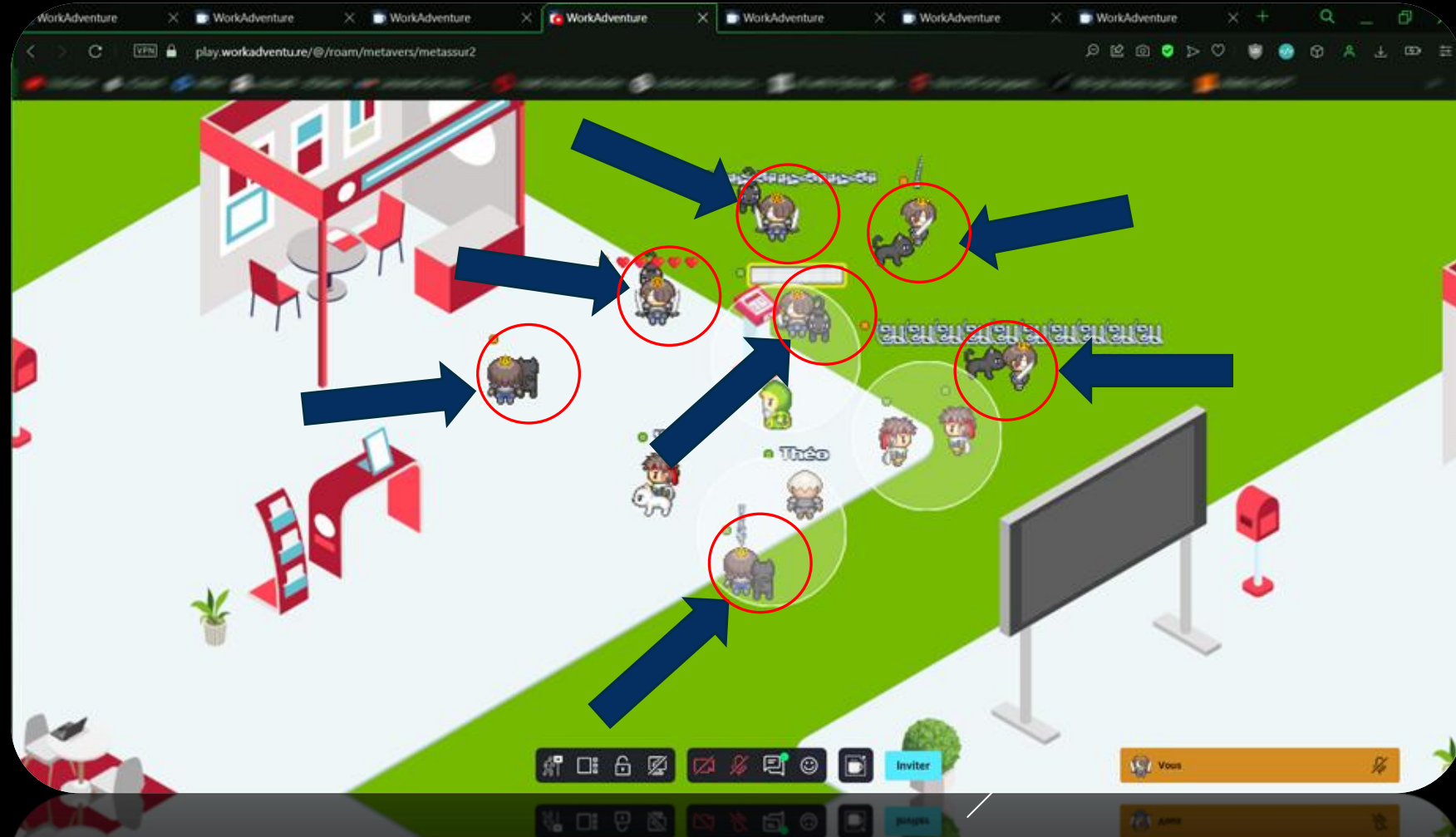
Solutions
Use the recommendations for hardening your HTTP Security Headers.

References

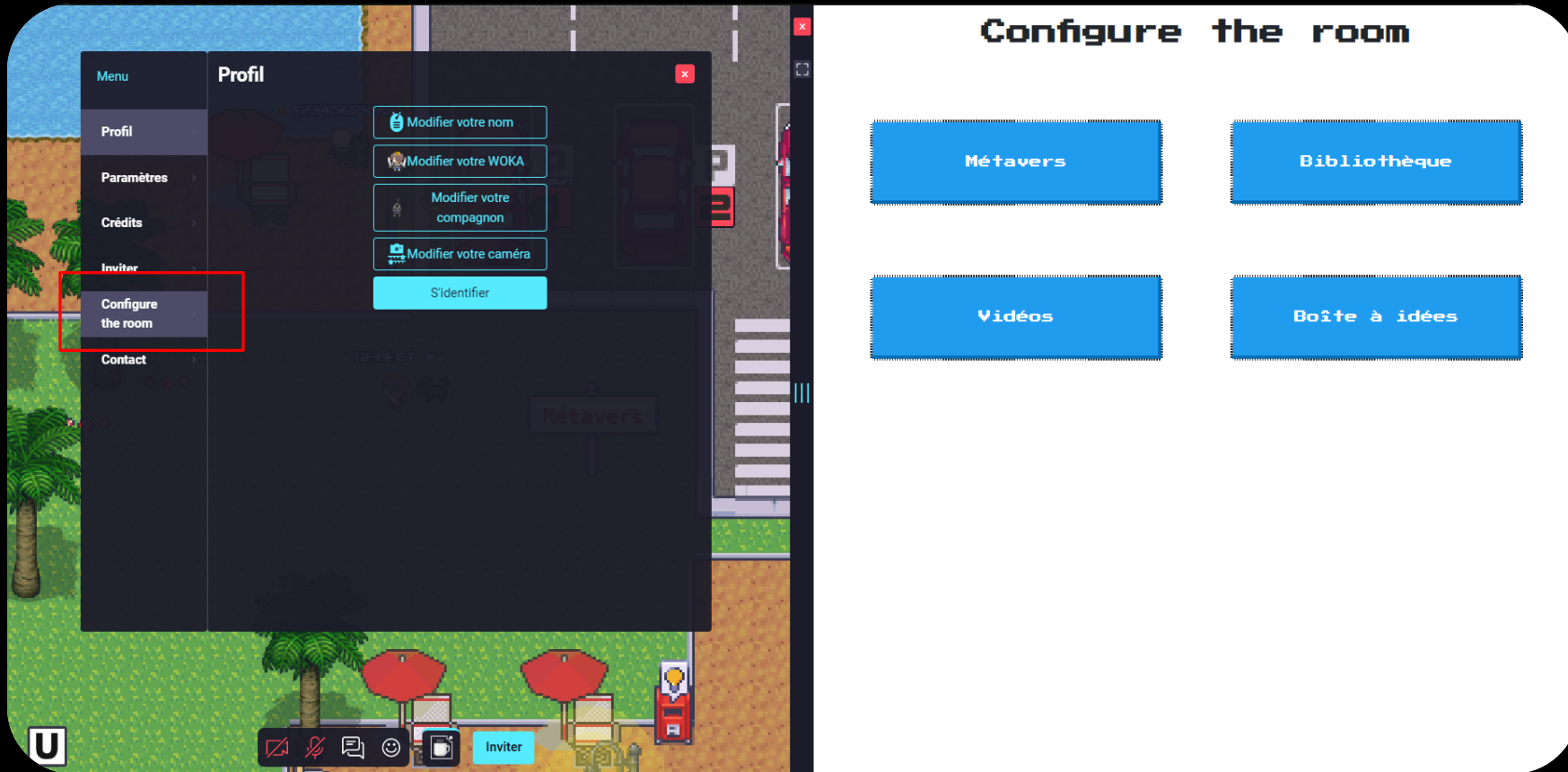
- [Netsparker: HTTP Security Headers: An Easy Way to Harden Your Web Applications](#)
- [KeyCDN: Hardening Your HTTP Security Headers](#)
- [OWASP: HTTP SECURITY HEADERS \(Protection For Browsers\) \(PDF\)](#)

III. LES PROBLÈMES DE SÉCURITÉ

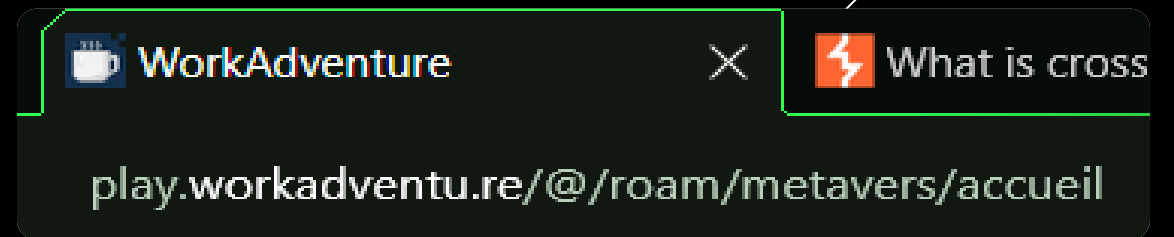
- ▶ Ingénierie sociale possible
 - ▶ Usurpation de pseudos
- ▶ Attaque par Spam
 - ▶ Une infinité de compte par utilisateurs
 - ▶ Pseudos vides donc non bannissables
 - ▶ Spam chat possible



III. LES PROBLÈMES DE SÉCURITÉ



- ▶ Accès au droits administrateurs
 - ▶ Modification des liens pour du phishing
 - ▶ Pleins pouvoirs sur les entreprises clientes
 - ▶ Aucune authentification nécessaire



III. LES PROBLÈMES DE SÉCURITÉ



Cf lien n°6 de la bibliothèque :)

Intégration
avec LinkedIn

Corriger les
failles de
sécurité

Metassûr

Renforcement
des aspects
légaux

Confidentialité

Travail de l'aspect
esthétique

Avoir une mini-carte

Pouvoir personnaliser sa
zone en tant
qu'entreprise

Changer l'angle des
rues pour pouvoir se
déplacer en diagonale

Avoir une place
centrale pour les
conférences